

```
1  # Municipal Data Center Security & Operations Requirements
2  # Issued by: Borough of Fairbanks IT Division
3  # 65 Requirements
4
5  ## Section 1: Physical Security (REQ-001 to REQ-010)
6
7  REQ-001: The facility must have 24/7 on-site security personnel with documented patrol
8  schedules.
9  REQ-002: All entry points must use multi-factor access control (badge + biometric).
10 REQ-003: CCTV coverage must include all server rooms, hallways, and loading docks with
11 90-day retention.
12 REQ-004: Visitor access must require pre-approval and escort at all times in secure
13 areas.
14 REQ-005: The facility must have a mantrap entry system for the primary data center floor.
15 REQ-006: Environmental monitoring must include temperature, humidity, and water leak
16 detection with automated alerts.
17 REQ-007: Fire suppression must use clean agent (FM-200 or Novec 1230) in all server
18 rooms.
19 REQ-008: Emergency power must sustain full operations for minimum 72 hours via generator
20 with automatic transfer.
21 REQ-009: Physical access logs must be retained for minimum 2 years and available for
22 audit within 24 hours.
23 REQ-010: All hardware disposal must follow NIST SP 800-88 Rev. 1 with certificates of
24 destruction.
25
26 ## Section 2: Network Security (REQ-011 to REQ-020)
27
28 REQ-011: Network segmentation must isolate production, development, and management
29 traffic on separate VLANs.
30 REQ-012: All external-facing services must be protected by a next-generation firewall
31 with application-layer inspection.
32 REQ-013: Intrusion detection and prevention systems must monitor all ingress and egress
33 traffic.
34 REQ-014: DNS filtering must block known malicious domains with real-time threat
35 intelligence updates.
36 REQ-015: Wireless networks must use WPA3-Enterprise with certificate-based
37 authentication.
38 REQ-016: Network access control must verify device compliance before granting access to
39 any VLAN.
40 REQ-017: All management interfaces must be accessible only via out-of-band management
41 network.
42 REQ-018: DDoS mitigation must be in place for all public-facing IP addresses with
43 automatic activation.
44 REQ-019: Network flow data must be collected and retained for minimum 1 year for
45 forensic analysis.
46 REQ-020: Quarterly external penetration testing must be performed by a CREST-certified
47 provider.
48
49 ## Section 3: Server & Endpoint Security (REQ-021 to REQ-035)
50
51 REQ-021: All servers must run a hardened OS configuration based on CIS Level 2
52 benchmarks.
53 REQ-022: Endpoint detection and response software must be deployed on all servers and
54 workstations.
55 REQ-023: Patch management must ensure critical vulnerabilities are remediated within 14
56 days of release.
57 REQ-024: All servers must use full-disk encryption with keys escrowed in a FIPS 140-2
58 Level 2 HSM.
59 REQ-025: Host-based firewalls must be enabled on all systems with deny-by-default rules.
60 REQ-026: Administrative access to servers must use a privileged access workstation (PAW).
61 REQ-027: All server builds must be created from approved golden images updated monthly.
62 REQ-028: File integrity monitoring must be active on all critical system files and
63 configurations.
64 REQ-029: Application whitelisting must be enforced on all production servers.
65 REQ-030: USB and removable media must be disabled on all servers via group policy.
66 REQ-031: Server certificates must use minimum 2048-bit RSA or 256-bit ECC keys.
```

44 REQ-032: Automated vulnerability scanning must run weekly against all internal systems.
45 REQ-033: Anti-malware signatures must update at least every 4 hours across all endpoints.
46 REQ-034: System logs must forward to the SIEM in real-time with no local-only logging
for production.
47 REQ-035: Container workloads must scan for vulnerabilities at build time and runtime.
48
49 ## Section 4: Identity & Access Management (REQ-036 to REQ-050)
50
51 REQ-036: All user accounts must use unique identifiers with no shared or generic
accounts.
52 REQ-037: Multi-factor authentication must be required for all remote access and
privileged operations.
53 REQ-038: Password policy must enforce minimum 16 characters with complexity requirements.
54 REQ-039: Privileged accounts must use just-in-time access with maximum 8-hour session
duration.
55 REQ-040: Service accounts must use managed identities or certificates with no static
passwords.
56 REQ-041: Access reviews must be conducted quarterly for all systems with privileged
access.
57 REQ-042: Role-based access control must be implemented following principle of least
privilege.
58 REQ-043: Account provisioning and deprovisioning must complete within 4 hours of HR
trigger.
59 REQ-044: Failed login attempts must lock accounts after 5 tries with 30-minute automatic
unlock.
60 REQ-045: All authentication events must be logged and correlated in the SIEM.
61 REQ-046: Conditional access policies must restrict login by location, device health, and
risk score.
62 REQ-047: Break-glass emergency accounts must exist with usage alerting and quarterly
testing.
63 REQ-048: Third-party access must use time-limited credentials with enhanced monitoring.
64 REQ-049: API authentication must use OAuth 2.0 with short-lived tokens (maximum 1 hour).
65 REQ-050: Directory synchronization must occur within 5 minutes to propagate access
changes.
66
67 ## Section 5: Data Protection (REQ-051 to REQ-060)
68
69 REQ-051: All data must be classified using a 4-tier scheme (Public, Internal,
Confidential, Restricted).
70 REQ-052: Encryption at rest must use AES-256 for all data classified Confidential or
above.
71 REQ-053: Encryption in transit must use TLS 1.3 for all internal and external
communications.
72 REQ-054: Database activity monitoring must alert on bulk data access or unusual query
patterns.
73 REQ-055: Data loss prevention must cover email, web upload, USB, and cloud storage
channels.
74 REQ-056: Backup data must be encrypted and stored in a geographically separate location.
75 REQ-057: Data retention and disposal must follow the Borough records schedule with
automated enforcement.
76 REQ-058: PII must be tokenized or masked in all non-production environments.
77 REQ-059: Cross-border data transfers must be prohibited without explicit legal counsel
approval.
78 REQ-060: Key management must include automated rotation every 90 days with revocation
capability.
79
80 ## Section 6: Incident Response & Continuity (REQ-061 to REQ-065)
81
82 REQ-061: An incident response plan must be maintained, reviewed semi-annually, and
tested via tabletop exercise.
83 REQ-062: Critical security incidents must be reported to Borough leadership within 2
hours of detection.
84 REQ-063: Forensic evidence preservation procedures must be documented and staff trained
annually.
85 REQ-064: Recovery time objective for Tier 1 systems must not exceed 4 hours.
86 REQ-065: Disaster recovery failover must be tested quarterly with documented results and

